

# CERTWATCH

## SERVERLESS TLS CERTIFICATE EXPIRY MONITOR ON AWS

Architecture decision record · Sakariyau Oseni · 24 September 2026

### DECISION REQUESTED

Endorse ADR-005 to ADR-007 before phases 3 to 5 are built.

# Document control

VERSION

0.1 · 24 September 2026 · first issue, draft for review

AUTHOR AND DECIDER

Sakariyau Oseni, maintainer

CLASSIFICATION

Public · portfolio project, in progress (phases 1–2 of 7 built)

SOURCE OF TRUTH

[github.com/ooseni/certwatch](https://github.com/ooseni/certwatch) · `template.yaml`, `README.md`, `docs/testing.md`

DECISION RECORDS

`docs/decisions` · MADR 4 · ADR-0001 to ADR-0007

# Executive summary

2 of 7

PHASES BUILT

100 + 9

UNIT + INTEGRATION TESTS

83%

UNIT COVERAGE

0

STORED AWS KEYS

SITUATION

Phases 1 and 2 are built and tested: the domain API on API Gateway, Lambda and DynamoDB, in one SAM template. Phases 3 to 5 add the daily checker, the SSRF guard and the OIDC pipeline.

DECISION REQUESTED

**Endorse ADR-005 to ADR-007 before phases 3 to 5 are built.**

OUTCOME

Expiry emails before certificates lapse, a checker that cannot reach private networks, and deploys with no stored AWS keys, inside the USD 40/month budget.

# Requirements and traceability

REQ-01

## ALERTING

Check every domain daily; email before expiry  
(alert\_days, default 30)  
→ ADR-005

REQ-02

## SECURITY

Never connect to private, loopback, link-local  
or metadata addresses  
→ ADR-006

REQ-03

## CREDENTIALS

No long-lived AWS keys, locally or in CI  
→ ADR-004, ADR-007

REQ-04

## TESTABILITY

Unit tests in under 1 s; the real template  
tested end to end before AWS  
→ ADR-001, ADR-004, ADR-007

REQ-05

## OPERABILITY

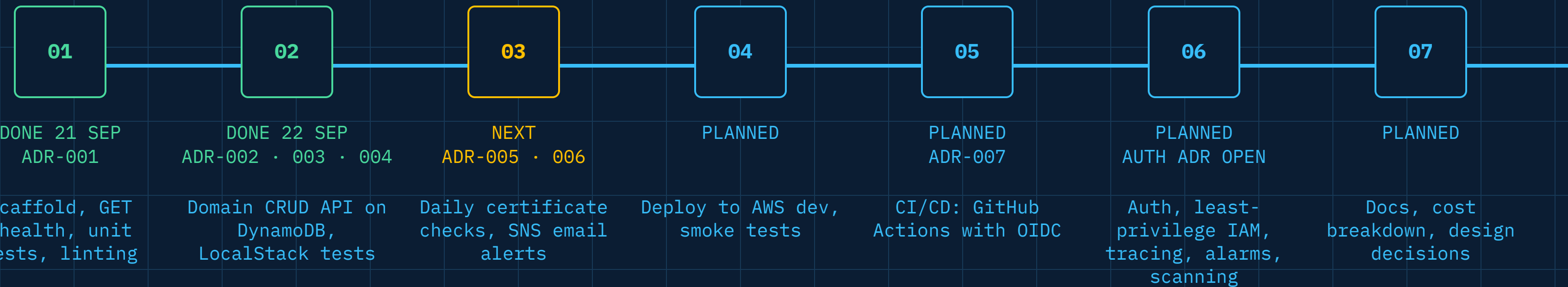
JSON logs (14 days), X-Ray tracing, one  
least-privilege role per function  
→ ADR-001, ADR-003, ADR-005

REQ-06

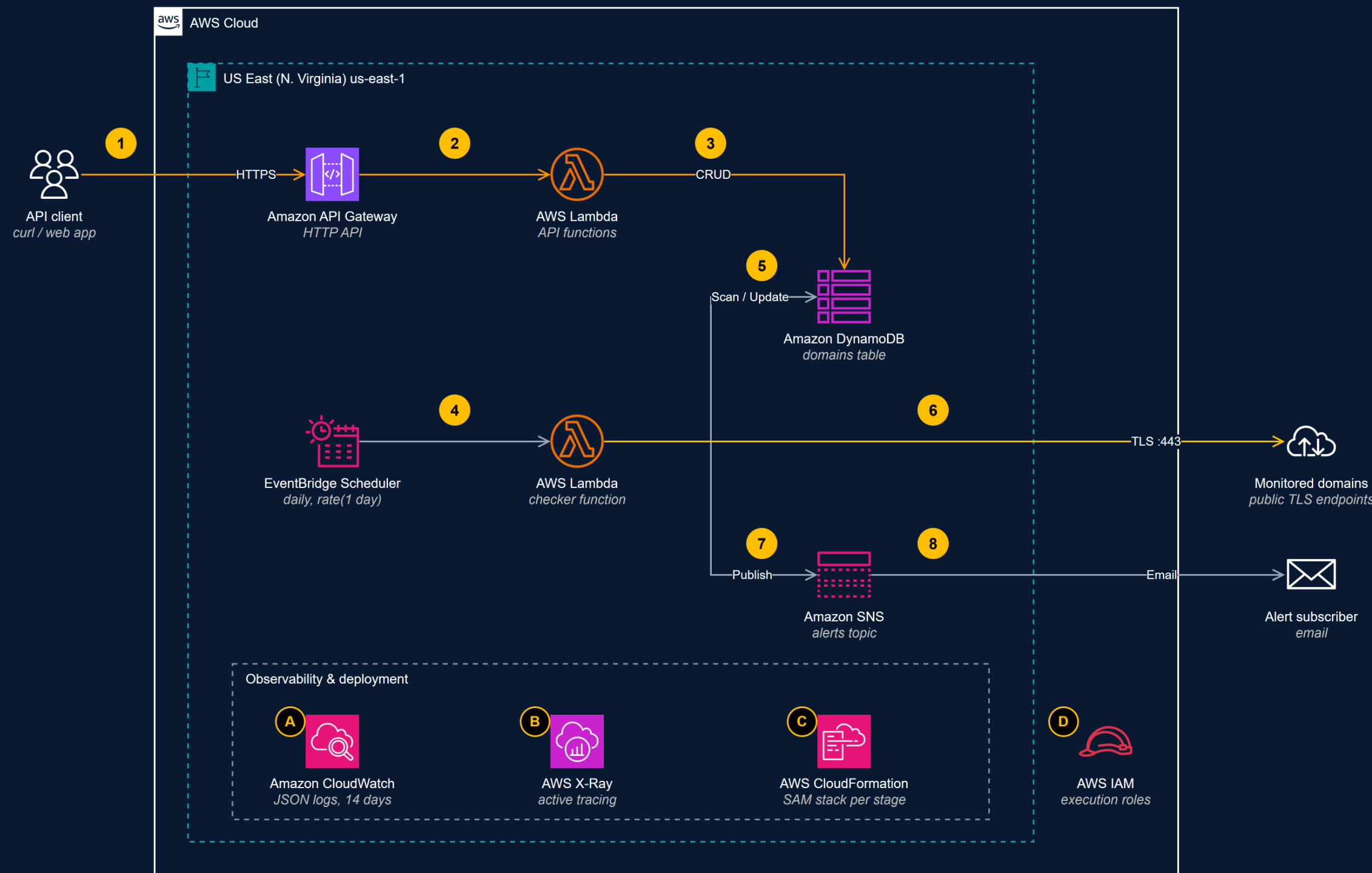
## COST

Stay inside the USD 40/month AWS credit  
budget; near-zero idle cost  
→ ADR-002, ADR-003, ADR-005

# Build status and roadmap



# Target architecture



## NOTES

- 1 The API client calls the HTTP API over HTTPS (/domains, /health)
- 2 API Gateway invokes the API functions
- 3 They create, read, update and delete domains in the table
- 4 EventBridge Scheduler starts the checker once a day (phase 3)
- 5 The checker scans the domains and records each result
- 6 It opens TLS on port 443 and reads each certificate's expiry
- 7 Certificates inside their alert window go to the alerts topic
- 8 SNS emails every confirmed subscriber

## KEYS

- A CloudWatch: JSON logs, 14 days
- B X-Ray: active tracing
- C CloudFormation: one SAM stack per stage
- D IAM: one least-privilege role per function

Built today: 1-3. Phase 3 adds 4-8.

Figure 1 - Target architecture: phases 1-2 built, phases 3-6 proposed

# Daily certificate check

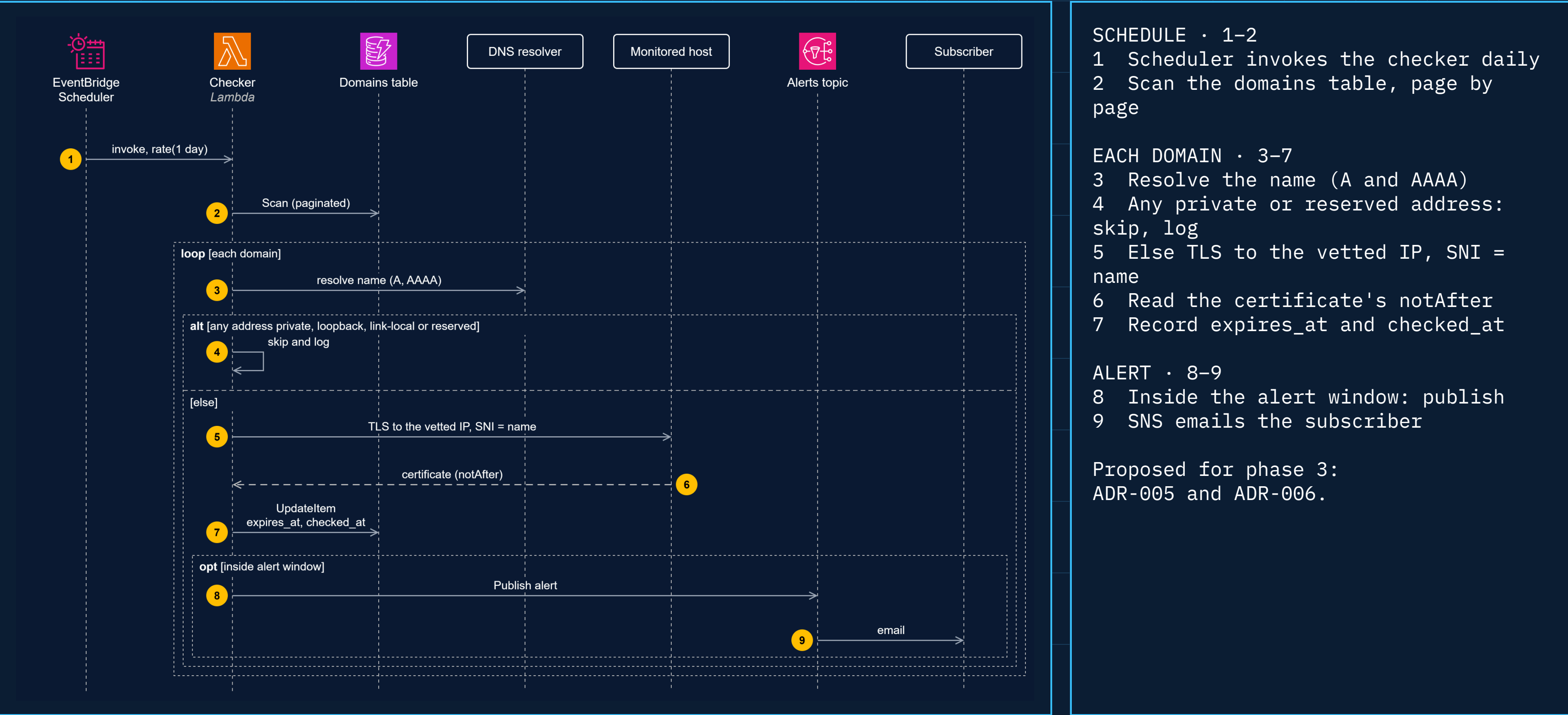
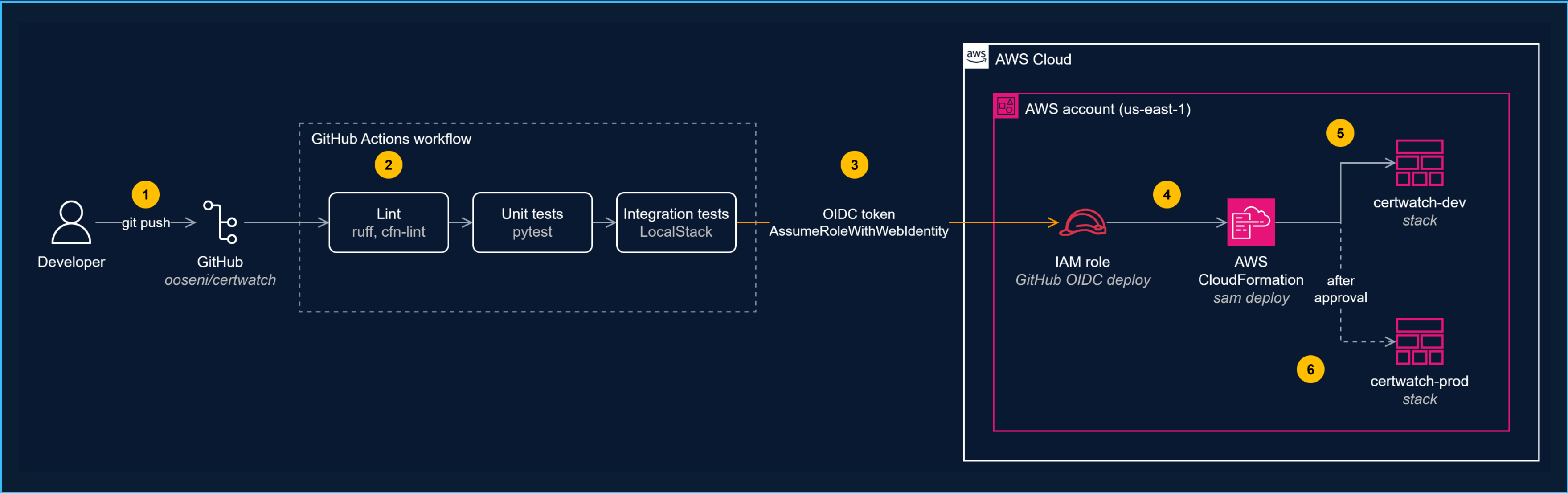


Figure 2 – One daily run with the check-time SSRF guard (phase 3, proposed)

# Delivery pipeline



- 1 Push a branch or open a pull request

2 Lint, unit tests, then integration tests on LocalStack

3 On main, swap the OIDC token for the deploy role

4 The role runs sam deploy, scoped to CertWatch stacks

5 CloudFormation updates certwatch-dev first

6 prod deploys only after a manual approval

Proposed for phase 5 (ADR-007). The deploy role trusts only `repo:ooseni/certwatch`.

Figure 3 - GitHub Actions to AWS with OIDC (phase 5, proposed)

# Decision log

| ID      | DECISION                                                            | STATUS, DATE        | CONF.  | REQUIREMENTS   |
|---------|---------------------------------------------------------------------|---------------------|--------|----------------|
| ADR-001 | Define the infrastructure with AWS SAM                              | ACCEPTED 2026-09-21 | HIGH   | REQ-04, 05     |
| ADR-002 | Serve the API through an API Gateway HTTP API                       | ACCEPTED 2026-09-21 | HIGH   | REQ-06         |
| ADR-003 | Store monitored domains in DynamoDB on demand                       | ACCEPTED 2026-09-22 | HIGH   | REQ-05, 06     |
| ADR-004 | Test the deployed stack against LocalStack                          | ACCEPTED 2026-09-22 | MEDIUM | REQ-03, 04     |
| ADR-005 | Check certificates daily with EventBridge Scheduler, Lambda and SNS | PROPOSED 2026-09-24 | HIGH   | REQ-01, 05, 06 |
| ADR-006 | Defend the checker against SSRF in two layers                       | PROPOSED 2026-09-24 | HIGH   | REQ-02         |
| ADR-007 | Deploy through GitHub Actions with OIDC                             | PROPOSED 2026-09-24 | HIGH   | REQ-03, 04     |

# ADR-001

## Define the infrastructure with AWS SAM

ACCEPTED · 2026-09-21

### 01 · CONTEXT AND DECISION

#### CONTEXT

A small serverless system (HTTP API, Lambda, DynamoDB, EventBridge Scheduler, SNS) that must run locally, deploy as one stack per stage, and teach serverless infrastructure as code. The next portfolio project uses Terraform, so this one exercises the AWS-native route.

#### DECISION

We will define every resource in one SAM template (template.yaml), deployed as one CloudFormation stack per stage (certwatch-dev, certwatch-prod), with no console changes.

#### DRIVERS

Delivery speed · Local testing · Learning goal  
Traces to REQ-04, 05

### 02 · OPTIONS, CHOSEN FIRST

#### CHOSEN · AWS SAM

- + Short definitions for functions, APIs and events
- + sam local and LocalStack run the same template
- + Native to AWS, no state file
- AWS only
- CloudFormation limits and slow rollbacks

#### OPTION 2 · Terraform

- + Multi-cloud skills
- + Plans show every change
- State file to store and lock
- More code for Lambda packaging

#### OPTION 3 · AWS CDK

- + Real code and abstractions
- + Synthesises CloudFormation
- Another layer to debug
- Local emulation goes through SAM anyway

### 03 · TRADE-OFF AND CONSEQUENCES

#### TRADE-OFF

The infrastructure code is tied to AWS; stacks inherit CloudFormation's rollback and resource limits

#### CONSEQUENCES

- + One template drives local runs, LocalStack and AWS
- + Least-privilege policies sit next to each function
- Terraform skills come from the next project, not this one
- Stack failures roll back slowly

#### CONFIRMATION

make lint validate runs cfn-lint and sam validate on every change; CloudFormation drift detection shows no out-of-band changes after phase 4.

# ADR-002

## Serve the API through an API Gateway HTTP API

ACCEPTED · 2026-09-21

### 01 · CONTEXT AND DECISION

#### CONTEXT

A small JSON API (/health, /domains) that is unauthenticated until phase 6 and must stay cheap. Phase 6 will add authentication, most likely with JWTs.

#### DECISION

We will expose the API through an API Gateway HTTP API with Lambda proxy integrations, and throttle every route to 10 requests/s (burst 20) until authentication arrives in phase 6.

#### DRIVERS

Cost · Auth path · Simplicity  
Traces to REQ-06

### 02 · OPTIONS, CHOSEN FIRST

#### CHOSEN · HTTP API

- + About 70% cheaper per request than REST APIs
- + Native JWT authorisers for phase 6
- + Lower latency
- No AWS WAF association
- No usage plans or API keys

#### OPTION 2 · REST API

- + AWS WAF, usage plans, request validation
- Higher cost per request
- More configuration

#### OPTION 3 · Lambda function URLs

- + No gateway to pay for
- No routing across functions
- IAM auth or none; no request throttling

### 03 · TRADE-OFF AND CONSEQUENCES

#### TRADE-OFF

The API has no WAF in front of it, so throttling and input validation carry the load until phase 6

#### CONSEQUENCES

- + Per-request cost is the lowest of the gateway options
- + JWT authorisers fit the phase 6 plan
- No WAF rate-based rules or managed rule sets
- Abuse protection is throttling only until phase 6

#### CONFIRMATION

Integration tests call every route through the HTTP API on LocalStack; the template pins ThrottlingRateLimit 10 and ThrottlingBurstLimit 20.

# ADR-003

## Store monitored domains in DynamoDB on demand

ACCEPTED · 2026-09-22

### 01 · CONTEXT AND DECISION

#### CONTEXT

One record per monitored domain, read by key from the API and read in full once a day by the checker. Hundreds to a few thousand domains (assumption), and idle most of the time.

#### DECISION

We will keep domains in a DynamoDB table in on-demand mode, keyed by the normalised domain name, with conditional writes for create, update and delete, and point-in-time recovery.

#### DRIVERS

Cost · Operability · Integrity  
Traces to REQ-05, 06

### 02 · OPTIONS, CHOSEN FIRST

#### CHOSEN · DynamoDB on demand

- + Pay per request, near zero when idle
- + Conditional writes give 409 on duplicates
- + Point-in-time recovery
- Listing is a full Scan
- No ad-hoc queries

#### OPTION 2 · Aurora Serverless v2

- + SQL and ad-hoc queries
- Lambda needs VPC access or the Data API
- Resume delay after a pause

#### OPTION 3 · Amazon RDS

- + Familiar relational model
- Pays for an instance around the clock
- Patching and connection limits

### 03 · TRADE-OFF AND CONSEQUENCES

#### TRADE-OFF

Listing and the daily check Scan the whole table, which is fine at this size

#### CONSEQUENCES

- + Duplicates are rejected atomically by a conditional write
- + No servers, patching or connections
- A Scan's cost grows with the table
- Reporting queries need an export

#### CONFIRMATION

LocalStack tests prove the conditional write (409) and Scan pagination; the template enables point-in-time recovery; review the Scan if the table passes 10,000 items.

# ADR-004

## Test the deployed stack against LocalStack

ACCEPTED • 2026-09-22

### 01 · CONTEXT AND DECISION

#### CONTEXT

Gaps that unit tests cannot close: the template, the IAM policies, API Gateway routing and real DynamoDB semantics. Testing on AWS for every change costs money and needs credentials.

#### DECISION

We will deploy the real SAM template to LocalStack and run end-to-end tests there, with dummy credentials and an explicit endpoint, before any AWS deployment.

#### DRIVERS

Testability · Credentials · Cost  
Traces to REQ-03, 04

### 02 · OPTIONS, CHOSEN FIRST

#### CHOSEN · LocalStack

- + Tests IAM, routing and DynamoDB semantics
- + No AWS cost or credentials
- + About 12 s per run
- HTTP APIs need a paid plan (trial now)
- Emulation can differ from AWS

#### OPTION 2 · moto only

- + Free and fast
- Never deploys the template
- No routing or IAM

#### OPTION 3 · A real AWS dev account

- + Real behaviour
- Needs credentials for every run
- Costs and slower feedback

### 03 · TRADE-OFF AND CONSEQUENCES

#### TRADE-OFF

A paid LocalStack plan is needed once the trial ends, or integration tests move to AWS in CI

#### CONSEQUENCES

- + 9 end-to-end tests pass against the real template
- + Dummy credentials cannot reach a real account
- The trial ends around 22 October 2026
- Smoke tests on AWS are still needed (phase 4)

#### CONFIRMATION

make ls-up ls-deploy ls-test passes (9 of 9);  
phase 4 smoke tests on AWS dev match; the  
table fixture refuses to run unless  
AWS\_ENDPOINT\_URL is LocalStack.

# ADR-005

## Check certificates daily with EventBridge Scheduler, Lambda and SNS

PROPOSED · 2026-09-24

### 01 · CONTEXT AND DECISION

#### CONTEXT

A phase 3 requirement to check every registered domain once a day and email a warning when a certificate is inside its alert window, at near-zero cost.

#### DECISION

We will run a checker Lambda once a day from EventBridge Scheduler. It scans the domains table, opens a TLS connection to each domain with a short timeout, records the expiry date, and publishes certificates inside their alert window to an SNS topic that emails subscribers.

#### DRIVERS

Alerting · Cost · Operability  
Traces to REQ-01, 05, 06

### 02 · OPTIONS, CHOSEN FIRST

#### CHOSEN · EventBridge Scheduler

- + Retries and a dead-letter queue per schedule
- + Within the free tier
- + Few moving parts
- One run is capped at 15 minutes
- Email only, to confirmed subscribers

#### OPTION 2 · EventBridge rule

- + Same result for a single daily trigger
- + Retries and dead-letter queue per target
- Cron in UTC only
- AWS recommends Scheduler for new schedules

#### OPTION 3 · Step Functions fan-out

- + Scales to any number of domains
- + Per-domain retries
- More cost and moving parts than needed now

### 03 · TRADE-OFF AND CONSEQUENCES

#### TRADE-OFF

A single run must finish inside Lambda's 15-minute limit; fan out with Step Functions if it grows

#### CONSEQUENCES

- + Alerts arrive without anyone checking a dashboard
- + Each result is stored for the next run
- Subscribers must confirm the SNS email subscription
- A failed day waits for the next run

#### CONFIRMATION

An integration test registers a host with an expired certificate and asserts an SNS publish; a CloudWatch alarm fires if the checker errors or runs past 80% of its timeout.

# ADR-006

## Defend the checker against SSRF in two layers

PROPOSED · 2026-09-24

### 01 · CONTEXT AND DECISION

#### CONTEXT

A checker that connects to hostnames anyone can register while the API is unauthenticated. A name that resolves to an internal address would turn it into a probe of private networks.

#### DECISION

We will keep registration-time validation (public DNS names only) and add a check-time guard: the checker resolves each name, refuses to connect if any address is private, loopback, link-local, multicast or reserved, and connects to the vetted address with SNI set to the name.

#### DRIVERS

Security · Integrity  
Traces to REQ-02

### 02 · OPTIONS, CHOSEN FIRST

CHOSEN · Validate, then guard at check time

- + Stops names that resolve inward later
- + Connecting to the vetted IP defeats DNS rebinding
- Split-horizon names cannot be monitored

#### OPTION 2 · Registration validation only

- + Nothing more to build
- A public name can resolve to a private IP later

#### OPTION 3 · Egress proxy or VPC firewall

- + Enforced outside the code
- NAT and firewall cost far above the budget

### 03 · TRADE-OFF AND CONSEQUENCES

#### TRADE-OFF

Hosts that resolve to private addresses are skipped and logged, never checked

#### CONSEQUENCES

- + Metadata and internal ranges are unreachable from the checker
- + The guard is testable in unit tests
- Some legitimate internal-only domains cannot be monitored

#### CONFIRMATION

Unit tests prove names resolving to 127.0.0.1, 10.0.0.0/8, 169.254.169.254 and ::1 are refused, including a rebinding case; the 66 registration-validation tests keep passing.

# ADR-007

## Deploy through GitHub Actions with OIDC

PROPOSED · 2026-09-24

### 01 · CONTEXT AND DECISION

#### CONTEXT

Phase 5 automation of lint, tests and deployment, where stored AWS access keys in CI are a common way for a small project's account to be compromised.

#### DECISION

We will deploy from GitHub Actions by exchanging the workflow's OIDC token for a deploy role whose trust policy is pinned to the ooseni/certwatch repository; prod deploys only after a manual approval on the GitHub environment.

#### DRIVERS

Credentials · Delivery speed  
Traces to REQ-03, 04

### 02 · OPTIONS, CHOSEN FIRST

#### CHOSEN · GitHub Actions + OIDC

- + No stored AWS keys
- + Trust scoped to one repository and branch
- A loose trust policy would let other repos deploy

#### OPTION 2 · Access keys in GitHub secrets

- + Simplest to set up
- Long-lived keys to leak and rotate

#### OPTION 3 · AWS CodePipeline

- + No external CI trust
- Cost and setup for a solo project

### 03 · TRADE-OFF AND CONSEQUENCES

#### TRADE-OFF

The deploy role's trust policy must pin the repository and branch exactly

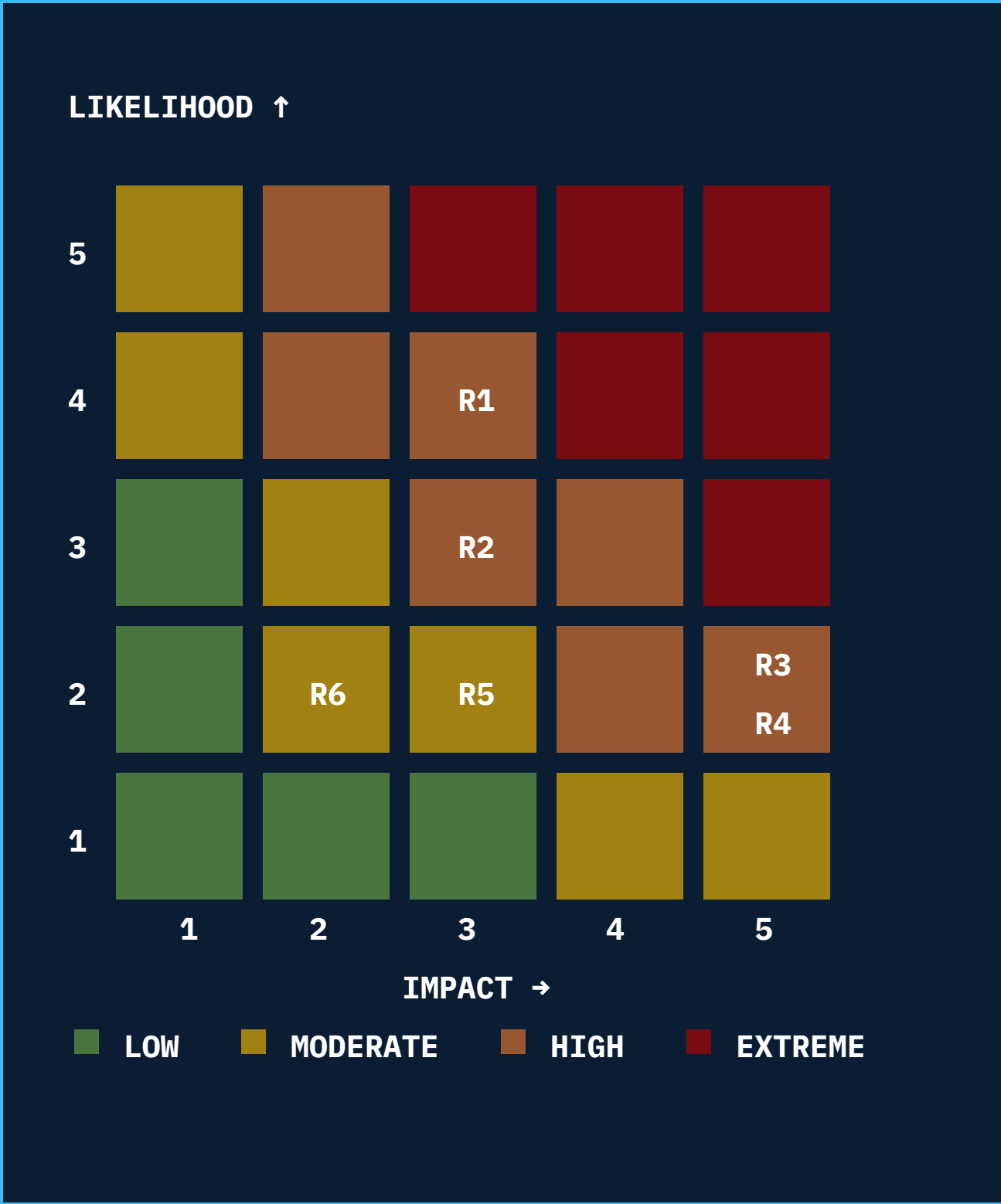
#### CONSEQUENCES

- + No AWS keys exist to leak
- + Every deploy is traceable to a commit
- The deploy role needs broad CloudFormation rights

#### CONFIRMATION

The IAM credential report shows no access keys; the trust policy's sub condition names repo:ooseni/certwatch; gitleaks keeps finding no secrets in history.

# Risks and mitigations



| ID | RISK                                                                                | L | I | SCORE      |
|----|-------------------------------------------------------------------------------------|---|---|------------|
| R1 | LocalStack trial ends; HTTP API tests stop<br>→ Decide paid plan or AWS tests in CI | 4 | 3 | 12 HIGH    |
| R2 | Public API abused before auth<br>→ Throttling 10 rps, validation, dev only          | 3 | 3 | 9 HIGH     |
| R3 | Checker used to probe internal hosts<br>→ Two-layer SSRF guard (ADR-006)            | 2 | 5 | 10 HIGH    |
| R4 | OIDC trust policy too broad<br>→ Pin sub to repo and branch                         | 2 | 5 | 10 HIGH    |
| R5 | Checker run outgrows 15 minutes<br>→ Duration alarm; Step Functions                 | 2 | 3 | 6 MODERATE |
| R6 | AWS spend over the credit budget<br>→ Budgets alert; pay per request                | 2 | 2 | 4 MODERATE |

Score = likelihood × impact, each rated 1 to 5.  
Bands: Low ≤ 3 · Moderate ≤ 6 · High ≤ 12 · Extreme ≥ 15.  
The maintainer owns all six risks; none is Extreme.

# Next steps

## NEXT STEPS

- 01 Endorse ADR-005 to ADR-007 at this review
- 02 Phase 3: build the daily checker with the two-layer SSRF guard
- 03 Phase 4: deploy to AWS dev and run smoke tests
- 04 Phase 5: GitHub Actions with OIDC, prod behind approval
- 05 By 22 Oct 2026: choose a LocalStack plan or AWS tests in CI (R1)
- 06 Before phase 6: write the authentication ADR

## OPEN DECISION

### PHASE 6 · API AUTHENTICATION

- Options on the table:
- Cognito user pool with the HTTP API JWT authoriser
  - IAM (SigV4) auth
  - API keys through a Lambda authoriser

ADR to be written before phase 6. ADR-002 keeps the JWT authoriser path open.

## DECISION REQUESTED

**Endorse ADR-005 to ADR-007 before phases 3 to 5 are built.**

# QUESTIONS?

---

SAKARIYAU OSENI

[github.com/ooseni/certwatch](https://github.com/ooseni/certwatch)